

ISO/IEC 27002 — Código de Buenas Prácticas para Controles de Seguridad de la Información

Material educativo original, no oficial, elaborado con fines didácticos. No reproduce el texto protegido de la norma ISO/IEC 27002.

1. Introducción y contexto

ISO/IEC 27002 es una norma "hermana" de ISO/IEC 27001 dentro de la familia ISO/IEC 27000. Mientras que ISO/IEC 27001 define **qué requisitos** debe cumplir un Sistema de Gestión de Seguridad de la Información para ser certificable, ISO/IEC 27002 explica **cómo implementar** en la práctica cada uno de los controles de seguridad listados en el Anexo A de 27001. Por eso se le describe frecuentemente como un "código de buenas prácticas" o una guía de implementación de controles, y **no es una norma certificable por sí misma**.

2. Historia y evolución

- Su origen también se remonta a **BS 7799-1**, adoptada como **ISO/IEC 17799** en 2000 y revisada en 2005.
- En 2007 fue renombrada como **ISO/IEC 27002:2005**, integrándose formalmente en la familia 27000.
- Se revisó en **2013**, alineándose con la nueva versión de ISO/IEC 27001.
- La versión vigente es **ISO/IEC 27002:2022**, que reestructuró y redujo los controles de 114 (organizados en 14 dominios) a **93 controles agrupados en 4 temas**: organizacionales, de personas, físicos y tecnológicos, alineándose con el nuevo Anexo A de ISO/IEC 27001:2022.

3. Objetivo y alcance

El propósito de la norma es proporcionar una referencia común de controles de seguridad de la información aplicables a cualquier tipo de organización, junto con orientación práctica sobre su propósito, implementación y consideraciones adicionales. Sirve como catálogo de referencia tanto para quienes implementan ISO/IEC 27001 como para organizaciones que buscan mejorar su seguridad sin necesariamente certificarse.

4. Organismo emisor

Al igual que ISO/IEC 27001, es desarrollada por el subcomité **SC 27** del comité técnico conjunto **ISO/IEC JTC 1**.

5. Estructura general (versión 2022)

La norma organiza sus 93 controles en cuatro cláusulas temáticas:

1. **Controles organizacionales** (cláusula 5) — 37 controles
2. **Controles de personas** (cláusula 6) — 8 controles
3. **Controles físicos** (cláusula 7) — 14 controles
4. **Controles tecnológicos** (cláusula 8) — 34 controles

Cada control se describe con: nombre, tipo de atributo (preventivo, detectivo, correctivo), propiedades de seguridad afectadas (confidencialidad, integridad, disponibilidad), conceptos de ciberseguridad relacionados, capacidades operativas y dominios de seguridad.

6. Conceptos y terminología clave

- **Control:** medida que modifica el riesgo de seguridad de la información.
- **Atributo de control:** metadato que permite clasificar y filtrar controles según distintas perspectivas (por ejemplo, tipo, propiedad de seguridad, dominio).
- **Control preventivo, detectivo y correctivo:** clasificación según el momento en que actúa el control respecto a un incidente.
- **Defensa en profundidad:** principio de aplicar múltiples capas de controles para reducir el riesgo global.

7. Principios fundamentales

- Los controles deben seleccionarse en función de una evaluación de riesgos, no aplicarse de forma genérica.
- La norma no es prescriptiva: ofrece orientación adaptable al contexto de cada organización.
- Los controles tecnológicos deben complementarse siempre con controles organizacionales y de personas.
- Se promueve el uso de atributos para facilitar vistas personalizadas del catálogo (por ejemplo, todos los controles relacionados con "prevención" o con "seguridad en la nube").

8. Categorías de controles explicadas

Controles organizacionales

Incluyen políticas de seguridad, gestión de activos, gestión de accesos, gestión de proveedores, gestión de incidentes, continuidad de negocio y cumplimiento normativo. Son la base estructural del sistema de seguridad.

Controles de personas

Cubren la selección y verificación de antecedentes de personal, acuerdos de confidencialidad, formación y concienciación en seguridad, y procesos disciplinarios ante incumplimientos.

Controles físicos

Se refieren a la protección de instalaciones, equipos, cableado, control de acceso físico a áreas seguras y eliminación segura de dispositivos y medios de almacenamiento.

Controles tecnológicos

Incluyen gestión de identidades y accesos, criptografía, seguridad de redes, prevención de fuga de datos, gestión de vulnerabilidades técnicas, desarrollo seguro de software, copias de seguridad y protección contra malware.

9. Proceso de uso práctico de la norma

5. Identificar los riesgos de seguridad relevantes para la organización (normalmente en el marco de ISO/IEC 27001 o ISO/IEC 27005).
6. Consultar el catálogo de ISO/IEC 27002 para identificar controles aplicables a cada riesgo.
7. Adaptar la implementación del control al contexto específico usando la guía de implementación de la norma.
8. Documentar la decisión en la Declaración de Aplicabilidad (SoA) exigida por ISO/IEC 27001.
9. Revisar periódicamente la eficacia del control implementado.

10. Relación con otras normas

- **ISO/IEC 27001:** 27002 es el complemento práctico de los controles del Anexo A de 27001.
- **ISO/IEC 27005:** aporta la metodología de evaluación de riesgos que determina qué controles de 27002 son necesarios.
- **ISO/IEC 27017 y 27018:** extienden los controles de 27002 a entornos de computación en la nube y protección de datos personales respectivamente.
- **NIST SP 800-53:** marco de controles de seguridad ampliamente usado en Estados Unidos, comparable en propósito a ISO/IEC 27002, útil para comparaciones académicas.

11. Aplicación práctica en informática

- Uso como checklist de referencia al diseñar arquitecturas de sistemas seguros.
- Apoyo en auditorías internas de seguridad de aplicaciones y redes.
- Base para políticas de desarrollo seguro (secure coding), gestión de parches y control de versiones.
- Referencia para diseñar programas de concienciación en ciberseguridad dirigidos a desarrolladores y usuarios finales.

12. Caso de aplicación ilustrativo

Un equipo de desarrollo detecta, mediante una evaluación de riesgos, que existe una alta probabilidad de fuga de credenciales en su pipeline de integración continua. Consultando ISO/IEC 27002, identifica controles tecnológicos relevantes como gestión de secretos, autenticación multifactor y registro de eventos (logging), además de controles organizacionales como una política de gestión de accesos privilegiados. La combinación de estos controles reduce el riesgo identificado.

13. Preguntas de repaso

- ¿Por qué ISO/IEC 27002 no es una norma certificable, a diferencia de ISO/IEC 27001?
- ¿Cuáles son las cuatro categorías de controles en la versión 2022 de la norma?
- ¿Qué son los "atributos de control" y para qué sirven?
- Explica la diferencia entre un control preventivo y uno detectivo, con un ejemplo de cada uno.
- ¿Cómo se conecta ISO/IEC 27002 con la Declaración de Aplicabilidad exigida por ISO/IEC 27001?

14. Glosario breve

- **SoA:** Declaración de Aplicabilidad, documento que justifica la inclusión o exclusión de cada control.
- **Defensa en profundidad:** estrategia de seguridad en capas.
- **Gestión de vulnerabilidades técnicas:** proceso de identificación, evaluación y corrección de debilidades en sistemas.

15. Para profundizar

Se recomienda revisar el texto oficial de ISO/IEC 27002:2022 a través de los canales autorizados de ISO, así como material formativo de organismos de certificación reconocidos.